

Cổng Giao dịch Ngân quỹ (2FA Banking Portal)

Môn học: IAW301 | Chủ đề: Xác thực Hai Yếu tố (Multi-Factor Authentication) | Số trang: 1

1. Bối cảnh & Mô tả hệ thống

Hệ thống quản lý tài chính và điều phối ngân quỹ của doanh nghiệp cung cấp cổng dịch vụ nội bộ cho nhân viên và quản lý thực hiện các tác vụ tài chính.

Theo chính sách an ninh của tổ chức:

- Các tài khoản có vai trò Quản trị viên Tài chính (`TREASURY_ADMIN`) bắt buộc phải thiết lập và sử dụng xác thực hai yếu tố (2FA) bằng mật khẩu và mã OTP.
- Chức năng chuyển ngân quỹ (`POST /api/v1/treasury/transfer`) là nghiệp vụ tài chính đặc quyền, yêu cầu mức độ bảo mật cao nhất để bảo vệ ngân sách doanh nghiệp.
- Quy trình đăng nhập gồm 2 giai đoạn: xác thực tên đăng nhập/mật khẩu tại `/login` và xác thực mã OTP tại `/verify-otp`.

2. Nhiệm vụ của sinh viên (Yêu cầu bài thi)

Nghiên cứu mã nguồn trong tệp `main.py` đi kèm và thực hiện các yêu cầu sau:

Câu 1: Phân tích vấn đề trong thiết kế hiện tại (3.0 điểm)

- Phân tích khiếm khuyết logic trong quy trình xác thực hai bước (2FA) ở đoạn mã nguồn trên.
- Giải thích nguyên nhân tại sao cơ chế 2FA trong hệ thống không mang lại giá trị bảo vệ thực tế trước nguy cơ truy cập trái phép.

Câu 2: Phân tích kịch bản và phương thức khai thác (3.5 điểm)

- Giả định trường hợp kẻ tấn công đã chiếm được mật khẩu của tài khoản `cfo_admin` (nhưng hoàn toàn không sở hữu thiết bị nhận mã OTP). Trình bày trình tự các bước hoặc yêu cầu HTTP cụ thể để kẻ tấn công có thể thực hiện giao dịch chuyển quỹ thành công.

Câu 3: Đề xuất phương án khắc phục (3.5 điểm)

- Đề xuất phương án thiết kế lại luồng quản lý phiên và cấp phát token nhằm đảm bảo nguyên tắc: yêu cầu nghiệp vụ bắt buộc phải bị từ chối nếu phiên chưa hoàn tất xác thực OTP. (Trình bày ý tưởng luồng xử lý phiên làm việc, có thể kèm mô tả hoặc đoạn mã nguồn minh họa)